

# Análisis de tienda-virtual

Arquitectura, seguridad, rendimiento, calidad y operación, cumplimiento legal en Colombia y modelo de negocio, con una hoja de ruta priorizada.

**En una frase:** la tienda tiene una base funcional amplia y varias decisiones de diseño buenas (inventario atómico, trazabilidad de descuentos, PQRS con plazo legal), pero **todavía no está lista para vender dinero real**: el flujo de pagos puede dejar pedidos e inventario en estados inconsistentes, hay riesgos de toma de cuentas en el inicio de sesión social, las sesiones no se pueden revocar y casi todo el trabajo reciente no está respaldado en Git.

---

Proyecto: D:\dev\up\tienda-virtual · Fecha: 28 de septiembre de 2026 · Alcance: revisión completa del backend (≈2.800 líneas), revisión dirigida del frontend (≈7.200 líneas), esquema de base de datos, 16 migraciones, configuración y estado del repositorio.

Método: lectura de código. No se ejecutaron ataques ni pruebas contra la base de datos real para no alterar datos; cada hallazgo indica el archivo y la línea donde se comprueba.

## 1. Resumen ejecutivo

### Madurez por área

| Área                    | Nivel           | Por qué                                                                                                                                                                     |
|-------------------------|-----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Arquitectura            | Intermedio      | Stack moderno y coherente (Next.js 16 + Express + Prisma + PostgreSQL). Faltan capa de servicios, almacenamiento de archivos externo y renderizado en servidor.             |
| Seguridad               | Básico          | Buena validación de entradas (zod) y controles de propiedad, pero hay riesgos altos en pagos, OAuth, sesiones y subida de archivos, y no hay límites de intentos.           |
| Integridad del negocio  | Básico          | El inventario reservado nunca se libera si el cliente no paga; un pago rechazado cancela el pedido y vacía el carrito; estados de pedido incompletos.                       |
| Rendimiento y SEO       | Intermedio-bajo | Todo el sitio se renderiza en el navegador: cascada de peticiones y páginas de producto invisibles para buscadores. Faltan índices en la base de datos.                     |
| Calidad y operación     | Básico          | Sin pruebas automáticas, sin CI, sin remoto de Git; 5 commits y ≈100 archivos sin versionar.                                                                                |
| Cumplimiento (Colombia) | Intermedio-bajo | PQRS con plazo de 15 días hábiles y páginas de retracto y garantía; falta autorización de datos personales, identificación del comerciante y factura electrónica.           |
| Producto y negocio      | Intermedio      | Diferenciadores reales (PQRS, trazabilidad, bilingüe) pero con fricciones que cuestan ventas: registro obligatorio, sin contraentrega, sin reintento de pago, sin métricas. |

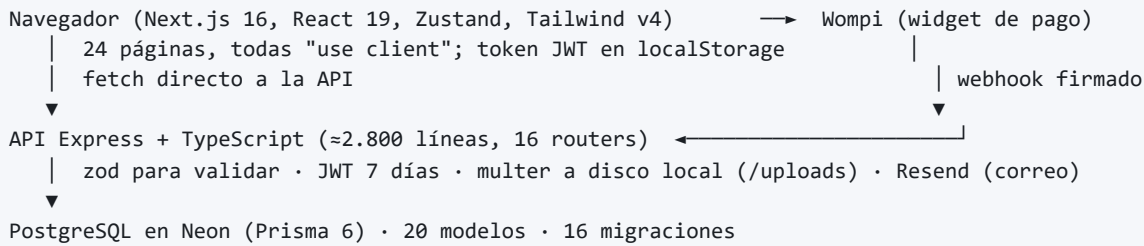
### Las 10 prioridades

| # | Acción                                                                                                                                                                         | Impacto | Esfuerzo |
|---|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|----------|
| 1 | <b>Versionar y respaldar hoy:</b> commit de todo el trabajo pendiente y un remoto privado (GitHub/GitLab). Hoy un fallo del disco borra 15 migraciones y la mitad del sistema. | Crítico | Horas    |
| 2 | <b>Pagos confiables:</b> webhook idempotente, validar estado y monto del pedido, un intento de pago activo por pedido, y no cancelar el pedido al primer rechazo.              | Alto    | 2–3 días |
| 3 | <b>Liberar inventario de pedidos no pagados</b> con una tarea periódica (p. ej. vencer a los 30–60 min).                                                                       | Alto    | 1 día    |
| 4 | <b>OAuth seguro:</b> parámetro <code>state</code> , exigir correo verificado, no vincular cuentas existentes sin confirmación, y no pasar el token en la URL.                  | Alto    | 1–2 días |
| 5 | <b>Sesiones revocables:</b> revisar en cada petición si el usuario sigue activo y con el mismo rol; tokens más cortos.                                                         | Alto    | 1 día    |
| 6 | <b>Subidas seguras y privadas:</b> tipo real del archivo, extensión controlada, adjuntos de PQRS con acceso autenticado, almacenamiento en la nube y rutas relativas.          | Alto    | 2–3 días |
| 7 | <b>Límites de intentos y cabeceras de seguridad</b> (login, registro, recuperar contraseña, PQRS, subidas; helmet).                                                            | Medio   | 1 día    |
| 8 | <b>Reglas de pedido completas:</b> despachar solo pagados, estados en preparación/entregado, validar producto activo y stock en carrito, copiar la dirección al pedido.        | Medio   | 2 días   |

|    |                                                                                                                                                            |       |             |
|----|------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------------|
| 9  | <b>SEO y velocidad:</b> catálogo y ficha de producto renderizados en servidor con metadatos, sitemap e índices en la base de datos.                        | Medio | 4–6 días    |
| 10 | <b>Cumplimiento:</b> autorización de tratamiento de datos (Ley 1581), NIT y razón social visibles, facturación electrónica, flujo de retracto y reversión. | Medio | 1–2 semanas |

Los esfuerzos son estimaciones para una persona que ya conoce el código.

## 2. Arquitectura



### Lo que está bien

- Stack actual, tipado de punta a punta y consistente entre proyectos (comidas-rapidas reutiliza los mismos patrones).
- Validación con zod en todas las rutas y verificación de propiedad ( `findFirst({ id, userId })` ) en pedidos, direcciones y PQRS.
- Reserva de inventario atómica: `updateMany ... stock >= cantidad` dentro de la transacción del checkout (`orders.routes.ts:92-100`).
- Dinero en enteros (COP), precio congelado en cada línea del pedido y enlace al descuento vigente: se puede explicar cualquier precio pasado.
- Recuperación de contraseña bien hecha: token aleatorio guardado como hash, 30 minutos, un solo uso y respuesta genérica.
- Webhook con cuerpo crudo y verificación de firma; manejador global de errores.
- Bitácoras de auditoría para cambios de dirección y de estado de PQRS.

### Debilidades estructurales

- **Lógica de negocio dentro de las rutas:** checkout, pagos y PQRS mezclan HTTP, reglas y correo. Difícil de probar y de reutilizar (p. ej. vencer pedidos desde una tarea).
- **Todo el frontend se renderiza en el navegador:** no hay Server Components ni metadatos por página (solo el layout raíz tiene metadata).
- **Archivos en el disco del servidor y guardados con URL absoluta** (`http://localhost:4000/uploads/...`, `uploads.routes.ts:77, 91`): se pierden en hosting efímero y todas las URL guardadas se rompen al cambiar de dominio.
- **Correos síncronos** dentro de la petición (incluido el webhook): si Resend falla, falla la operación.
- **Configuración sin validar al arrancar:** un `JWT_SECRET` ausente se descubre en la primera petición, no al iniciar.

### Recomendación de arquitectura

1. Extraer servicios de dominio ( `checkoutService`, `paymentService`, `orderLifecycle` ) y dejar las rutas como capa delgada. Es la base para probar pagos y vencer pedidos.
2. Introducir una tabla *outbox* o una cola simple para correos y tareas (vencer pedidos, recordatorios de PQRS por vencer).
3. Almacenamiento de objetos (Cloudflare R2, S3 o Cloudinary) guardando solo la clave del archivo; URL pública solo para imágenes de producto y URL firmada para adjuntos de PQRS.
4. Catálogo, categorías y ficha de producto como Server Components con revalidación (ISR); carrito, cuenta y administración pueden seguir en el cliente.
5. Validar el entorno al iniciar con un esquema zod y fallar temprano.

### 3. Seguridad

Ordenados por severidad. “Escenario” describe cómo se explotaría o cómo falla en la práctica.

| Sev.  | Hallazgo                                                                                                                                 | Escenario                                                                                                                                                                                                                                                                                                                                                                              | Corrección                                                                                                                                                                                                                                        |
|-------|------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Alta  | <b>Webhook de pagos sin idempotencia ni control de estado</b><br>payments.routes.ts:112-159                                              | Wompi reintenta webhooks. Un evento DECLINED repetido devuelve el stock dos veces (inventario inflado). Cada visita a la página de pago crea un Payment nuevo (WompiButton.tsx; en desarrollo, dos por el doble efecto de React): si un intento se rechaza el pedido se cancela y devuelve stock, y si otro intento se aprueba después el pedido pasa a PAID sin inventario reservado. | Procesar cada transacción una sola vez (guardar providerTransactionId único); transiciones permitidas por estado (PENDING→PAID solamente); comparar amount_in_cents y moneda con el pedido; reutilizar el intento pendiente en vez de crear otro. |
| Alta  | <b>OAuth sin state y vinculación automática por correo</b><br>oauth.routes.ts:29-47, 59-72, 122-133                                      | Sin state, un atacante puede iniciar sesión a la víctima en la cuenta del atacante (CSRF de login). Además, si alguien entra con Facebook o Google usando el correo de un cliente existente — incluido un administrador —, la cuenta existente queda vinculada y el atacante entra a ella. No se revisa email_verified de Google.                                                      | Generar y verificar state (cookie firmada); exigir correo verificado; vincular una cuenta existente solo después de que el usuario inicie sesión con su contraseña; nunca vincular cuentas de administración automáticamente.                     |
| Alta  | <b>Sesiones no revocables</b><br>auth.middleware.ts:12-27, jwt.ts                                                                        | El token dura 7 días y el middleware solo verifica la firma: un administrador desactivado o degradado conserva su acceso hasta que el token venza. Restablecer la contraseña tampoco cierra sesiones abiertas.                                                                                                                                                                         | Consultar estado y rol del usuario en cada petición (con caché de segundos, como ya hace comidas-rapidas); guardar una “versión de sesión” en el usuario e invalidarla al cambiar contraseña, rol o estado.                                       |
| Alta  | <b>Subida de archivos: tipo declarado por el cliente y extensión del nombre original</b><br>uploads.routes.ts:21-28, 35, 47; index.ts:35 | Cualquier cliente registrado puede subir x.html declarando image/png; se guarda como .html y express.static lo sirve como página web desde el dominio de la API (phishing o XSS en ese dominio). Los adjuntos de PQRS (fotos y videos de reclamos, datos personales) quedan públicos para cualquiera que tenga la URL.                                                                 | Detectar el tipo por los bytes del archivo, asignar la extensión según ese tipo, servir con X-Content-Type-Options: nosniff y Content-Disposition; adjuntos de PQRS detrás de autenticación o URL firmada.                                        |
| Media | <b>Sin límites de intentos en ninguna ruta</b>                                                                                           | Fuerza bruta de contraseñas en /auth/login; envío masivo de correos con /auth/forgot-password (costo en Resend y reputación del dominio); un usuario puede llenar el disco con adjuntos de 25 MB sin límite.                                                                                                                                                                           | Limitador por correo e IP en autenticación, por usuario en PQRS y subidas, y cuota de almacenamiento.                                                                                                                                             |
| Media | <b>Token JWT en la URL y en localStorage</b><br>oauth.routes.ts:49-51, auth.store.ts                                                     | El token del inicio social queda en el historial del navegador y en registros de servidores. En localStorage, cualquier XSS lo puede leer.                                                                                                                                                                                                                                             | Entregar un código de un solo uso que el frontend canjea por el token; a mediano plazo, cookie httpOnly + SameSite.                                                                                                                               |

|              |                                                                               |                                                                                                                                                                                          |                                                                                                |
|--------------|-------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------|
| <b>Media</b> | <b>El cliente ve el correo del administrador</b><br>orders.routes.ts:145, 161 | GET /orders/me y /orders/:id incluyen discountLog.createdBy.email: cualquier cliente con un producto en descuento conoce el correo de quien administra la tienda (objetivo de phishing). | Quitar createdBy de las respuestas al cliente.                                                 |
| <b>Media</b> | <b>HTML sin escapar en correos</b><br>email.service.ts:48, 61, 92, 147-149    | Asunto y respuesta de PQRS, nombre de la dirección, transportadora y guía se insertan tal cual en el HTML del correo: se pueden inyectar enlaces o contenido engañoso.                   | Escapar todo valor dinámico (o usar plantillas como React Email).                              |
| <b>Media</b> | <b>Credenciales por defecto</b><br>prisma/seed.ts:17                          | admin@tienda.test / admin1234: si el seed se ejecuta en producción, el panel queda abierto.                                                                                              | Leer la contraseña inicial de una variable de entorno y forzar el cambio en el primer ingreso. |
| <b>Baja</b>  | <b>Sin cabeceras de seguridad</b><br>(helmet, CSP, HSTS)                      | Aumenta el impacto de cualquier XSS futuro y permite incrustar el sitio en marcos ajenos.                                                                                                | helmet en la API; CSP en Next.js permitiendo solo checkout.wompi.co como script externo.       |
| <b>Baja</b>  | <b>URL de adjuntos libres</b><br>pqrs.routes.ts:23, juridico/page.tsx:139     | attachmentUrl acepta cualquier texto: un cliente puede enlazar un sitio externo que el equipo jurídico abrirá como "adjunto".                                                            | Aceptar solo claves de archivos subidos por el mismo usuario.                                  |
| <b>Baja</b>  | <b>Detalles criptográficos</b><br>wompi.service.ts:47, jwt.ts:19              | La firma del webhook se compara con === (no en tiempo constante) y jwt.verify no fija el algoritmo.                                                                                      | crypto.timingSafeEqual; algorithms: ["HS256"].                                                 |
| <b>Info</b>  | <b>URL construida con la cabecera Host</b><br>uploads.routes.ts:77, 91        | Detrás de un proxy devolverá http:// (contenido mixto) o un host interno.                                                                                                                | Usar una variable PUBLIC_FILES_URL o guardar rutas relativas.                                  |

## 4. Reglas de negocio e integridad de datos

Errores que no son de seguridad pero que cuestan dinero, inventario o clientes.

| Sev.  | Problema                                                                                                                         | Consecuencia y corrección                                                                                                                                                                                                                                                                                        |
|-------|----------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Alta  | <b>El stock de pedidos no pagados nunca se libera</b><br>orders.routes.ts:92-121                                                 | El checkout descuenta inventario al crear el pedido <code>PENDING</code> . Si el cliente cierra la pestaña, ese stock queda bloqueado para siempre y el producto aparece agotado. <i>Corrección:</i> vencer pedidos <code>PENDING</code> después de 30–60 minutos devolviendo el stock en una transacción.       |
| Alta  | <b>Un pago rechazado pierde la venta</b><br>payments.routes.ts:143-158                                                           | El primer rechazo cancela el pedido y el carrito ya se vació en el checkout: el cliente no puede reintentar con otra tarjeta ni con PSE y debe armar todo de nuevo. <i>Corrección:</i> dejar el pedido en <code>PENDING</code> ante un rechazo, permitir otro intento y cancelar solo por vencimiento.           |
| Media | <b>La página de éxito no verifica el pago</b><br>checkout/success/page.tsx                                                       | Muestra “Gracias por tu compra” también cuando Wompi redirige con un pago rechazado. <i>Corrección:</i> consultar el estado del pedido o de la transacción y mostrar aprobado, pendiente o rechazado (con botón para reintentar).                                                                                |
| Media | <b>Estados de pedido incompletos</b><br>orders.routes.ts:198-227                                                                 | Solo existe la transición a <code>SHIPPED</code> ; <code>PROCESSING</code> y <code>DELIVERED</code> no se pueden alcanzar desde ninguna ruta. Además se puede despachar un pedido <code>PENDING</code> o <code>CANCELLED</code> . <i>Corrección:</i> máquina de estados explícita con bitácora (igual que PQRS). |
| Media | <b>Productos desactivados se pueden comprar</b><br>cart.routes.ts:45-49,<br>orders.routes.ts:52-57,<br>products.routes.ts:96-109 | Ni el carrito ni el checkout revisan <code>isActive</code> , y la ficha de un producto inactivo sigue siendo pública. El carrito tampoco valida stock ni cantidad máxima al agregar. <i>Corrección:</i> validar en carrito y checkout; 404 para inactivos en la ficha pública.                                   |
| Media | <b>Descuento sin duración rompe la trazabilidad</b><br>products.routes.ts:151-167, 206-210                                       | Si el admin envía porcentaje sin días, el producto queda rebajado indefinidamente, sin registro en <code>ProductDiscountLog</code> y sin aparecer en “Ofertas relámpago”. <i>Corrección:</i> exigir ambos campos juntos.                                                                                         |
| Media | <b>El pedido apunta a una dirección editable</b><br>schema.prisma:240-256                                                        | Si el cliente edita su dirección después de comprar, el pedido “cambia” de destino (la bitácora lo registra, pero el despacho usa la dirección actual). <i>Corrección:</i> copiar la dirección al pedido al momento de pagar.                                                                                    |
| Baja  | <b>Filtro de precio sobre el precio base</b><br>products.routes.ts:49-51                                                         | Un producto rebajado a \$80.000 no aparece al filtrar “hasta \$90.000” si su precio base es \$100.000.                                                                                                                                                                                                           |
| Baja  | <b>Plazo de PQRS sin festivos</b><br>lib/businessDays.ts                                                                         | Colombia tiene 18 festivos al año: el plazo calculado queda más corto que el legal (lado seguro, pero genera alertas de vencimiento falsas). También depende de la zona horaria del servidor.                                                                                                                    |
| Baja  | <b>Envíos simulados</b><br>carrier.service.ts                                                                                    | Tarifa fija por prefijo de código postal y peso: el costo cobrado puede diferir del costo real de la transportadora (margen negativo en envíos pesados o voluminosos: no usa peso volumétrico aunque el producto tiene dimensiones).                                                                             |

## 5. Rendimiento, escalabilidad y SEO

---

### Frontend

- **Renderizado 100 % en el cliente.** Las 24 páginas son `"use client"`. La página de inicio hace al cargar cinco peticiones independientes (categorías, filtros, productos, ofertas, reseñas) después de descargar y ejecutar JavaScript; en un celular de gama media con 4G eso son segundos de pantalla vacía.
- **SEO casi nulo para un e-commerce.** La ficha de producto no tiene título, descripción, Open Graph ni datos estructurados (`schema.org/Product`) propios; no hay `sitemap.xml` ni `robots.txt`. Google indexará poco y los enlaces compartidos por WhatsApp no mostrarán foto ni precio.
- **Sin caché de datos:** categorías y filtros cambian muy poco y se piden en cada visita.
- **Configuración atada a desarrollo:** `next.config.ts` solo permite imágenes de `localhost:4000` y Unsplash.

*Recomendación:* inicio, categoría y ficha de producto como Server Components con `revalidate` (p. ej. 60 s) y `generateMetadata`; `app/sitemap.ts` y `app/robots.ts`; mantener en el cliente solo lo interactivo (carrito, filtros, cuenta).

### Base de datos

- **Faltan índices en claves foráneas** (PostgreSQL no los crea solo): `Order.userId`, `OrderItem.orderId`, `OrderItem.productId`, `CartItem.productId`, `Payment.orderId`, `Pqrs.userId`, `ProductDiscountLog.productId`, `Product.categoryId`. Con miles de pedidos, "mis pedidos" y el panel harán recorridos completos.
- **Búsqueda con `contains` sin índice** (`products.routes.ts:47`) y solo por nombre: recorre toda la tabla y no encuentra por marca o descripción. Usar `pg_trgm` o búsqueda de texto completo en español.
- **Listados del panel sin paginación** (`/orders`, `/users`, `/pqrs`) que además traen relaciones completas.

### Backend

- Correos síncronos (se crea un cliente de Resend por correo) dentro del webhook y del despacho: latencia y reintentos innecesarios.
- Archivos en disco local: impide tener más de una instancia de la API y se pierden en cada despliegue en plataformas efímeras.

## 6. Calidad, pruebas y operación

**Riesgo inmediato — control de versiones.** El repositorio tiene 5 commits (el último del 25 de septiembre) y **no tiene remoto**. Sin versionar: 32 archivos modificados (+1.893 / -298 líneas) y cerca de 70 archivos nuevos, entre ellos 15 de las 16 migraciones, los routers de PQRS, OAuth, reseñas, subidas y usuarios, y todo el panel de administración nuevo. Un fallo del disco, un borrado accidental o un `git checkout` se lleva la mayor parte del proyecto.

| Aspecto              | Estado                                   | Recomendación                                                                                                                                                                                                                                      |
|----------------------|------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Pruebas automáticas  | Ninguna (ni <code>script test</code> )   | Empezar por pruebas de extremo a extremo de checkout, webhook (aprobado, rechazado, repetido, fuera de orden), concurrencia de stock y permisos. <code>comidas-rapidas</code> ya tiene un arnés e2e reutilizable (17 suites, limpieza automática). |
| Lint y formato       | No configurados                          | ESLint + Prettier; en CI aunque el proxy corporativo bloquee dependencias locales.                                                                                                                                                                 |
| Integración continua | No existe                                | GitHub Actions: <code>tsc</code> , pruebas, <code>prisma migrate diff</code> para detectar desviaciones del esquema.                                                                                                                               |
| Despliegue           | No definido                              | Frontend en Vercel; API en Render, Railway o Fly.io; archivos en R2 o S3; dominio con HTTPS (requisito de Wompi para la URL de retorno).                                                                                                           |
| Observabilidad       | Solo <code>console.log</code>            | Registro estructurado (pino) con identificador de petición; Sentry en frontend y API; alerta si un webhook falla.                                                                                                                                  |
| Respaldos            | Los de Neon (según plan)                 | Confirmar la retención de Neon y probar una restauración; los archivos subidos no tienen respaldo.                                                                                                                                                 |
| Configuración        | <code>.env</code> correctamente ignorado | Validar variables al arrancar; secretos distintos por ambiente; rotar cualquier credencial que se haya compartido en conversaciones.                                                                                                               |

### Accesibilidad y experiencia (revisión rápida)

- Modo oscuro sin parpadeo y bilingüe en todo el sitio: bien resuelto.
- Hay imágenes con `alt=""` en contenido (miniaturas del formulario de producto) y solo 10 `aria-label` en todo el frontend: revisar botones solo con ícono (carrito, tema, idioma, WhatsApp) para lectores de pantalla.
- El diccionario de traducciones (988 líneas, ambos idiomas) viaja completo al navegador; se puede dividir por idioma.

## 7. Cumplimiento legal en Colombia

Orientación técnica, no asesoría jurídica: conviene validarla con un abogado antes de lanzar.

| Norma / tema                                                           | Qué hay hoy                                                                                                   | Qué falta                                                                                                                                                                                                                                                                      |
|------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Ley 1581 de 2012</b><br>(protección de datos personales)            | Se recolectan correo, teléfono, direcciones y adjuntos con datos sensibles.                                   | Política de tratamiento publicada; autorización previa, expresa e informada al registrarse (casilla, fecha y versión aceptada); canal para consultas y reclamos sobre datos; eliminación o anonimización de la cuenta a solicitud; adjuntos de PQRS privados.                  |
| <b>Ley 1480 de 2011</b> (Estatuto del Consumidor) — ventas a distancia | Páginas de términos, envíos, garantía y retracto (art. 47); PQRS con plazo de 15 días hábiles y rol jurídico. | Identificación del vendedor en el sitio (razón social, NIT, dirección, teléfono, correo — art. 50); flujo real de retracto y de reversión del pago (art. 51) con estados de devolución y reembolso; resumen del pedido y costo total antes de pagar con constancia al cliente. |
| <b>Facturación electrónica DIAN</b>                                    | No existe.                                                                                                    | Emitir factura electrónica por cada venta. comidas-rapidas ya integra Alanube (ambiente de pruebas): el módulo se puede adaptar.                                                                                                                                               |
| <b>Impuestos en precios</b>                                            | Precio único por producto.                                                                                    | Registrar el IVA (tarifa y base) por producto para la factura y los reportes.                                                                                                                                                                                                  |
| <b>Reseñas</b>                                                         | Solo compradores reales pueden opinar; correo enmascarado.                                                    | Moderación y derecho de respuesta; no ocultar reseñas negativas (publicidad engañosa).                                                                                                                                                                                         |

## 8. Modelo de negocio

### Qué es hoy

Una tienda B2C de un solo comercio, con catálogo pequeño (13 productos en 4 categorías con taxonomía estilo MercadoLibre), pago en línea con Wompi (aún en ambiente de pruebas) y envío nacional cotizado con tarifas fijas. Ingreso: margen de producto más el cobro del envío. Costos variables por pedido: comisión de Wompi (porcentaje más valor fijo más IVA; verificar la tarifa vigente del plan), envío real de la transportadora, empaque y correo transaccional.

#### Diferenciadores reales

- PQRS con plazo legal, línea de tiempo y área jurídica: poco común en pymes y genera confianza.
- Trazabilidad completa de descuentos: base para campañas medibles.
- Bilingüe y modo oscuro: sirve a público extranjero y a compras regaladas desde el exterior.
- Botón de WhatsApp y datos de contacto editables.

#### Fricciones que cuestan ventas

- **Registro obligatorio** antes de comprar: es una de las principales causas de abandono de carrito.
- **Sin pago contra entrega**, muy usado en Colombia por desconfianza en pagos en línea.
- **Un rechazo pierde el pedido** (sección 4) y la página de éxito puede mentir.
- **Sin recuperación de carritos**, cupones, lista de deseos ni aviso de "volvió a haber existencias".
- **Reseñas solo de la tienda**, no por producto: la prueba social que más convierte está en la ficha.

### Métricas que hoy no se pueden ver

El panel solo lista pedidos. Faltan: ventas por día, ticket promedio, conversión (visitas → carrito → pago), tasa de rechazo de pagos, abandono de carrito, productos más vendidos y con más devoluciones, margen por producto (no se registra el costo) y tiempo de respuesta de PQRS frente al plazo (el endpoint de estadísticas existe; falta el tablero).

### Oportunidades priorizadas

| Oportunidad                                            | Por qué                                                                                                       | Esfuerzo |
|--------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|----------|
| Compra como invitado + PSE y Nequi en Wompi            | Menos pasos y los medios de pago más usados en el país.                                                       | Medio    |
| Pago contra entrega en ciudades principales            | Aumenta conversión; controlar el riesgo con tope de valor y confirmación por WhatsApp.                        | Medio    |
| SEO de producto + catálogo para Google Shopping y Meta | Tráfico orgánico y anuncios con el catálogo sincronizado (requiere páginas renderizadas en servidor).         | Medio    |
| Recuperación de carritos y avisos de reposición        | Recupera ventas perdidas con correo o WhatsApp (con autorización de datos).                                   | Bajo     |
| Costo por producto y reporte de margen                 | Saber qué descuentos son rentables; comidas-rapidas ya tiene este modelo (costo, margen, ingeniería de menú). | Bajo     |
| Programa de puntos                                     | Recompra; se puede portar desde comidas-rapidas.                                                              | Medio    |

---

|                                                             |                                                                                    |      |
|-------------------------------------------------------------|------------------------------------------------------------------------------------|------|
| Venta multicanal (MercadoLibre)<br>con inventario unificado | Alcance del marketplace sin perder la tienda propia como canal de<br>mejor margen. | Alto |
|-------------------------------------------------------------|------------------------------------------------------------------------------------|------|

---

**Posicionamiento sugerido:** competir de frente con MercadoLibre o Falabella en catálogo general es difícil para un solo comercio. Rinde más un nicho con curaduría y buen servicio posventa —donde el PQRS con respaldo jurídico, la garantía clara y la atención por WhatsApp son el argumento— y usar los marketplaces como canal de adquisición.

## 9. Hoja de ruta

| Fase                      | Contenido                                                                                                                                                                                                               | Duración estimada |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------|
| 0 · Hoy                   | Commit de todo lo pendiente, remoto privado, rotar secretos que se hayan compartido, contraseña del admin del seed.                                                                                                     | Horas             |
| 1 · Dinero seguro         | Webhook idempotente con máquina de estados y validación de monto; reintento de pago sin perder el pedido; vencimiento de pedidos <code>PENDING</code> ; página de resultado real; pruebas e2e de todo el flujo de pago. | 1 semana          |
| 2 · Cuentas seguras       | OAuth con <code>state</code> y correo verificado; sesiones revocables; límites de intentos; helmet; correos escapados; quitar el correo del admin de las respuestas.                                                    | 1 semana          |
| 3 · Archivos y despliegue | Almacenamiento en la nube, validación por contenido, adjuntos privados, migrar URL absolutas a claves; CI; desplegar en un ambiente de pruebas con HTTPS.                                                               | 1 semana          |
| 4 · Operación             | Estados de pedido completos con bitácora; validaciones de carrito y checkout; dirección copiada al pedido; paginación e índices; tablero de ventas.                                                                     | 1–2 semanas       |
| 5 · Crecimiento           | SEO (Server Components, metadatos, sitemap, datos estructurados); compra como invitado; contra entrega; recuperación de carritos; reseñas por producto.                                                                 | 2–3 semanas       |
| 6 · Formalización         | Autorización de datos, identificación del comerciante, factura electrónica (reutilizando Alanube), flujo de retracto y reversión, IVA por producto.                                                                     | 2 semanas         |

**Lo que se puede reutilizar de comidas-rapidas.** Varias soluciones que ese proyecto ya tiene probadas atienden hallazgos de este informe: verificación del estado del usuario en cada petición con caché corta y desconexión al cambiar rol, limitador de intentos, arnés de pruebas e2e con limpieza de datos, integración con Alanube para factura electrónica, costos y margen por producto, y programa de puntos.

### Cómo se hizo este análisis

Lectura completa de los 16 routers, servicios, middleware y esquema Prisma del backend; revisión dirigida del frontend (cliente de API, almacenamiento de sesión, checkout y pago, subida y visualización de adjuntos, configuración de Next.js, renderizado y metadatos); revisión del historial y del estado de Git. Las referencias `archivo:línea` apuntan al código a la fecha del informe. No se ejecutaron pruebas de intrusión ni se modificaron datos.